

Data Security Analysis in Online Payment Processing



Mohamad Abdelnaby
7/1/2024



Section One: Data Governance



Strategic Data Security Policies

IT Staff should perform a data classification annually, or when there are notable business or technology changes.

Because it will allow you to prioritize often limited time and resources to protect the right things.

IT Staff should perform an application and critical system classification annually, or when there are notable business or technology changes.

Expanding on the previous data classification, by knowing which applications contains the most critical important data you would know which applications you should protect and backup more.

IT Staff should perform a regulatory assessment annually, or when there are notable business or technology changes.

In order to always stay compliant with regulatory compliances because it will help manage and minimize enterprise liabilities by understanding current and emerging regulations.



Data Classification

Confidential: Data is considered confidential if data loss would have a catastrophic impact on the business.

Internal: Internal Data is a little less serious and includes data where the impact would be "significant" but not quite catastrophic.

Public: Anything in the public data would have minimal impact on the business if lost or exposed.

Categorize each dataset into one of the three data types

Dataset	Data Type
Employee profile data	Confidential
Customer profile data	Confidential
Company email	Internal
Repository of previously published blogs	Public
Internal employee newsletters	Internal
Technology engineering diagrams	Confidential
Intellectual property	Confidential



Data Regulations

Confidential	Gramm-Leach-Bliley Act (GLB): Because the company handles financial information so they have to be compliant with Gramm-Leach-Bliley Act PCI-DSS: Because the company is an online processing payments so they deal with payment methods and information so they have to be compliant with PCI-DSS General Data Protection Regulation (GDPR): The company deals with US & Europe Customers' data so they have to be compliant with the GDPR California Consumer Privacy Act: If the company has Californian customers they need to be compliant with this regulation.
Internal	Federal Trade Commission Act: requires companies to engage in security practices to ensure information security.
Public	Breach notification laws: in case of any breach where customer information has been disclosed to unauthorized individuals, the company has to notify the authorities and customers.



Regulatory Compliance

3.2 Do not store sensitive authentication data after authorization (even if it is encrypted). Render all sensitive authentication data unrecoverable upon completion of the authorization process. Issuers and related entities may store sensitive authentication data if there is a business justification, and the data is stored securely. (PCI-DSS)

3.5 Document and implement procedures to protect any keys used for encryption of cardholder data from disclosure and misuse. (PCI-DSS)

3.6 Fully document and implement key management processes and procedures for cryptographic keys used for encryption of cardholder data. (PCI-DSS)

3.7 Ensure that related security policies and operational procedures are documented, in use, and known to all affected parties. (PCI-DSS)

4.1 Use strong cryptography and security protocols to safeguard sensitive cardholder data during transmission over open, public networks (e.g. Internet, wireless technologies, cellular technologies, General Packet Radio Service [GPRS], satellite communications). Ensure wireless networks transmitting cardholder data or connected to the cardholder data environment use industry best practices to implement strong encryption for authentication and transmission. (PCI-DSS)

4.3 Ensure that related security policies and operational procedures are documented, in use, and known to all affected parties. (PCI-DSS)

7.1 Limit access to system components and cardholder data to only those individuals whose job requires such access. (PCI-DSS)



Section Two: Data Confidentiality



Securing Disks

Place the screenshot from the Keys page of the Key Vault you created, with the generated key.

Microsoft Azure

Search resources, services, and docs (G+)

Copilot

odl_user_261419@udact...
UDACITY (UDACITYLABS ONMIC...

Home > Y4M0keyvault

Y4M0keyvault | Keys ☆ ...

Key vault

Search

Generate/Import Refresh Restore Backup Manage deleted keys

The key 'Y4M0RsaKey' has been successfully created.

Name	Status	Expiration date
Y4M0RsaKey	✓ Enabled	

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Access policies

Events

Objects

Keys

Secrets

Certificates

Settings

Monitoring

Automation

Help



Securing Disks

Place the screenshot from Key page of the Disk Encryption Set you created

The screenshot displays the Azure portal interface for managing a Disk Encryption Set. The breadcrumb navigation at the top reads: Home > Disk Encryption Sets > Y4MODES. The main heading is 'Disk Encryption Sets' with the subtext 'Udacity (udacitylabs.onmicrosoft.com)'. Below this, there are links for '+ Create' and 'Manage view'. A search bar is present with the placeholder text 'Filter for any field...'. On the left, a list of resources shows 'Y4MODES' selected. The central pane shows the 'Y4MODES | Key' page. The left sidebar of this pane lists navigation options: Overview, Activity log, Access control (IAM), Tags, Settings, Resources, Key (selected), Properties, Locks, Automation, and Help. The main content area of the 'Key' page includes a search bar, 'Save', 'Discard', and 'Give feedback' buttons. It contains instructions: 'Select a key vault and a key in the same subscription and region as the disk encryption set to replace the current key in your encryption set. [Learn more](#)'. The 'Current key' field displays the URL 'https://Y4M0keyvault.vault.azure.net/keys/Y4M0RsaKey/78eefe22f13d41fda...' with a copy icon. Below this is a 'Change key' link. The 'Auto key rotation' section has an unchecked checkbox. The 'User-assigned identity' section has a 'Select an identity' link. The 'Multi-tenant application' section has a 'Select an application' link. A blue information icon with a message states: 'You are required to select the user-assigned managed identity first.'



Securing Disks

Place the screenshot from the Encryption page of the Disk you created

Home > Virtual machines > LabVM-261419 | Disks > y4m0encrypteddisk

 **y4m0encrypteddisk** | Encryption ☆ ⋮

Disk

Search

Save Discard Refresh Give feedback

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Settings

Configuration

Size + performance

Encryption

Networking

Disk Export

Properties

Locks

Monitoring

Automation

Help

Changes to encryption settings can only be made when the disk is unattached or the managing virtual machine(s) are deallocated.

Azure offers server-side encryption with platform-managed keys by default for managed disks. You may optionally choose to use a customer-managed key. [Learn more](#)

Key management ⓘ

Customer-managed key: Y4M0DES



Section Three: Data Integrity



File Integrity Verification

The original DSysLaunch2pm.dll hash:

B029D03AA6CD3ED4D5B3860881937EE255184D430990661E261C1CE3251184D4

The original SSysLaunch9am.dll hash:

76A586439464553482A529108A0BAD0FECDA3F9337BAE2098697F170026B6733

Based on the file hashes generated, DSysLaunch2pm.dll has been tampered with as the hashes don't match. (Data integrity has been compromised)

However the SSysLaunch9am.dll hash matches so it remains the same and we can confirm that it's safe

```
PS C:\Users\demouser\Documents\Esnd-4> Get-FileHash .\DSysLaunch2pm.dll
```

Algorithm	Hash	Path
-----	----	----
SHA256	A029D03AA6CD3ED4D5B3860881937EE255184D430990661E261C1CE32511F56E	C:\Users\demouser\Documents\E...

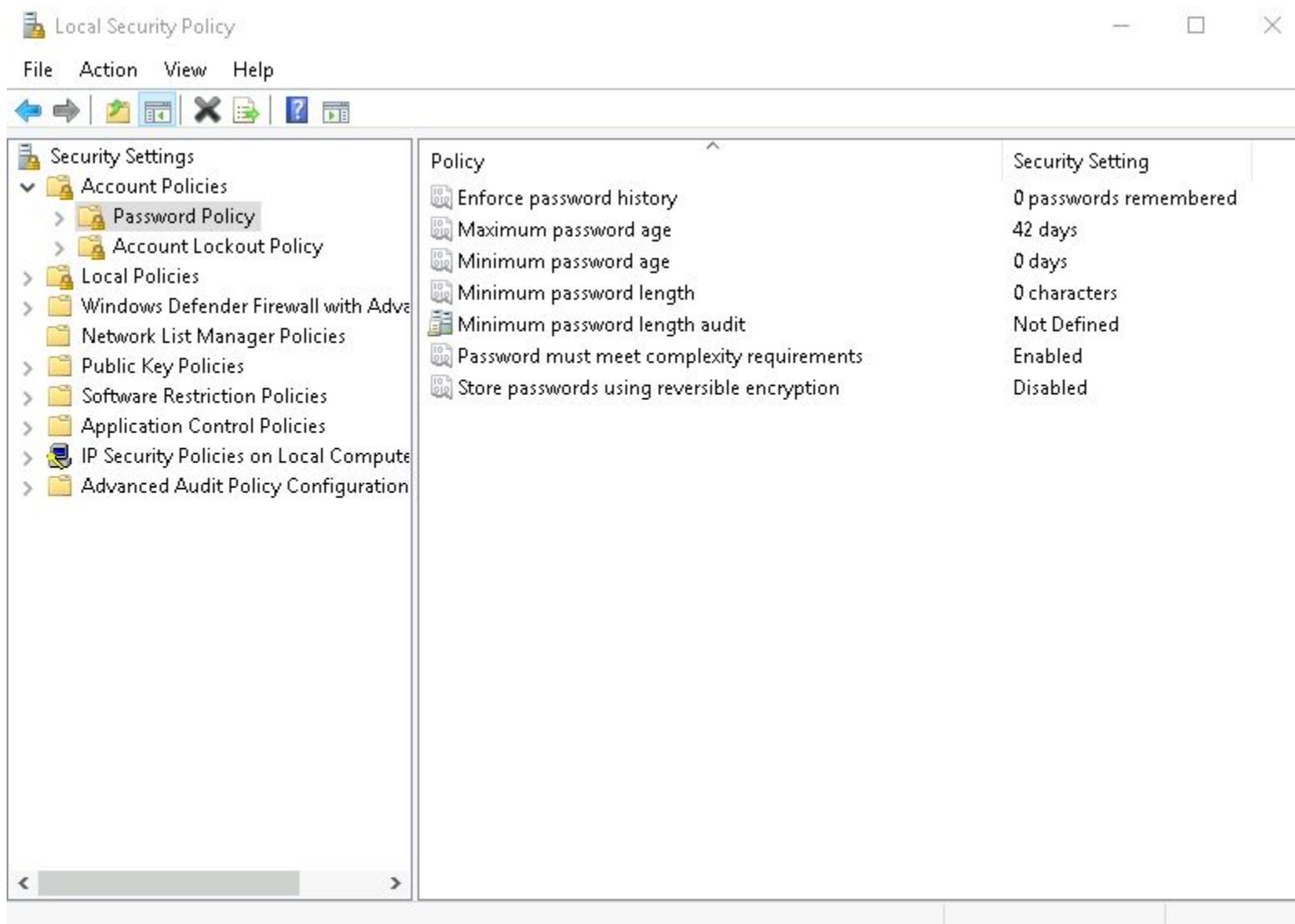
```
PS C:\Users\demouser\Documents\Esnd-4> Get-FileHash .\SSysLaunch9am.dll
```

Algorithm	Hash	Path
-----	----	----
SHA256	76A586439464553482A529108A0BAD0FECDA3F9337BAE2098697F170026B6733	C:\Users\demouser\Documents\E...



Auditing Security Settings

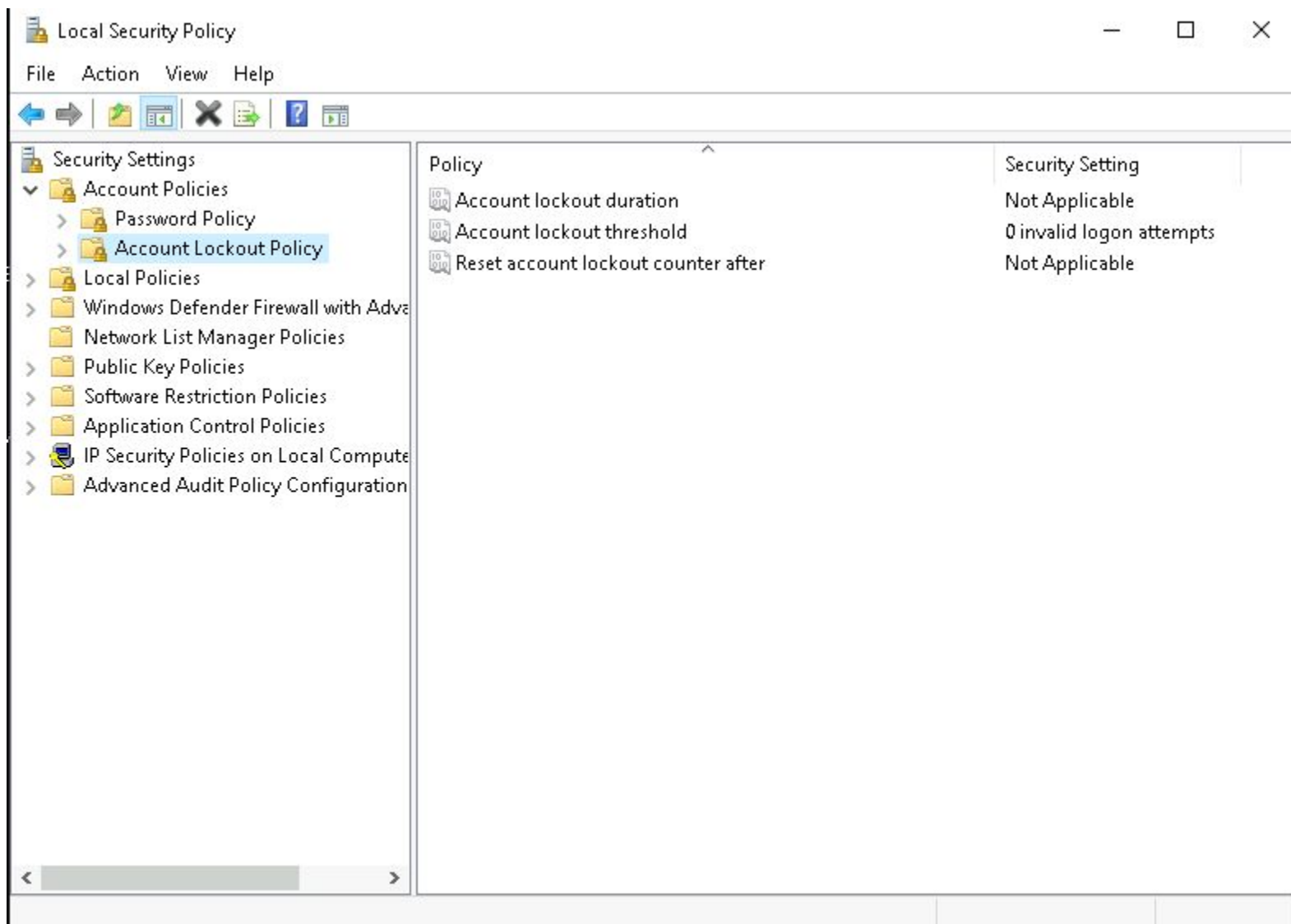
Place the screenshot of the password policy screen here





Auditing Security Settings

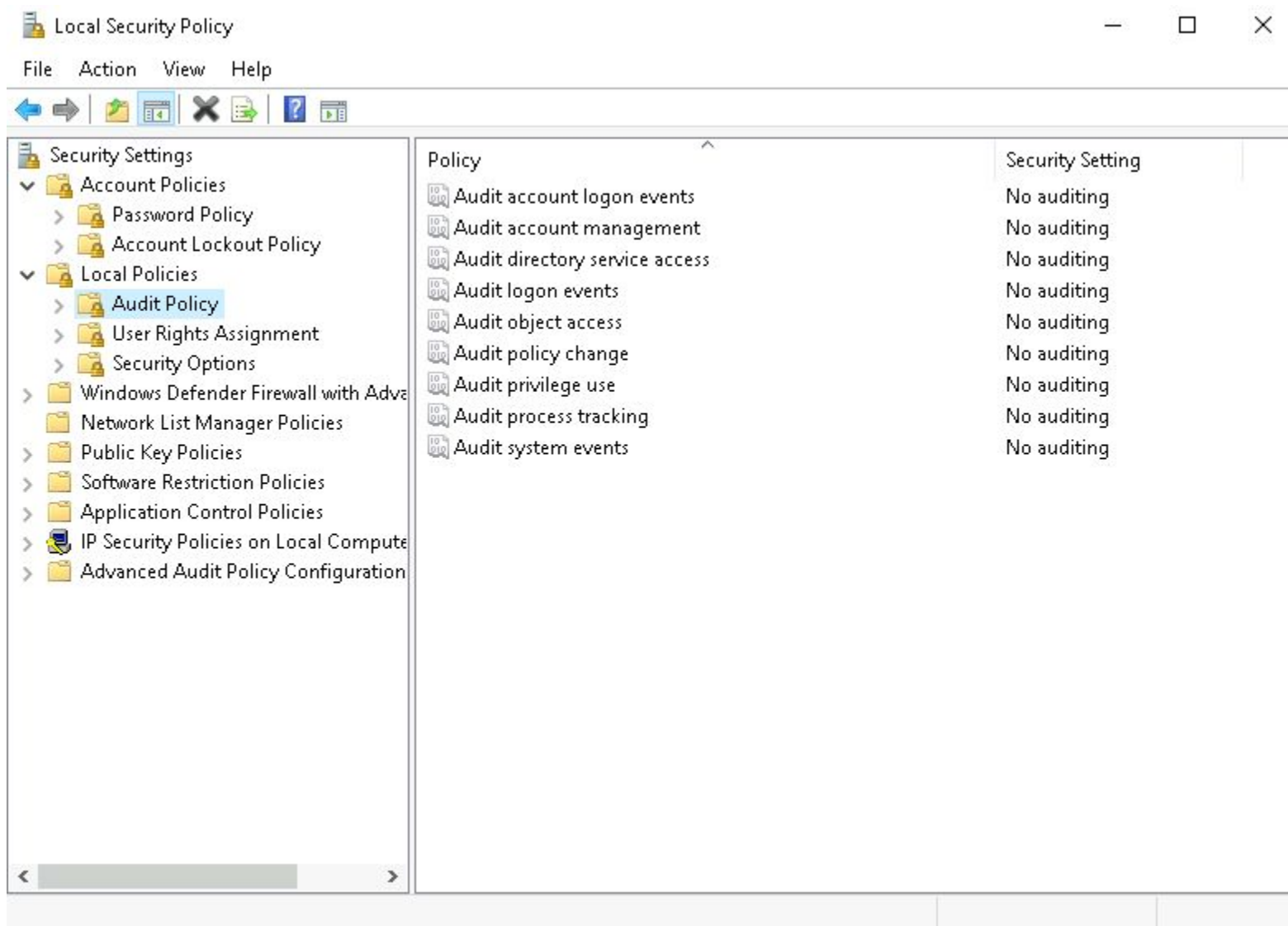
Place the screenshot of account lockout policy screen here





Auditing Security Settings

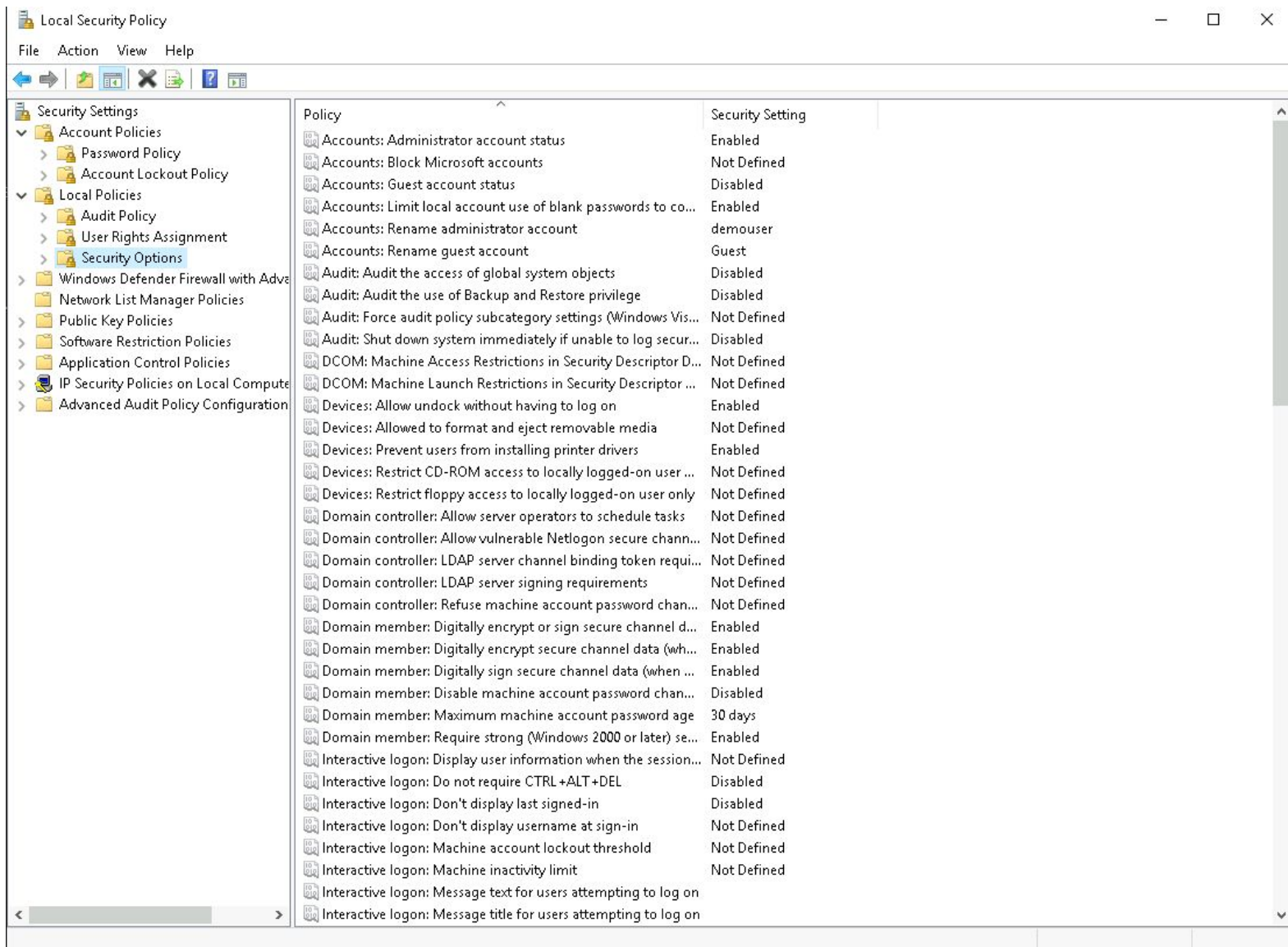
Place the screenshot of the audit policy screen here





Auditing Security Settings

Place the screenshot of the security options screen here





Enhancing VM Security

1. Password Policy

Password length policy is set to 0 characters the recommended is to have it of a minimum of 8 characters with a combination of Upper case, lower case, and special characters.

Additionally, The maximum age of password is set to 42, the recommended is 30 days.

2. Account Lockout Policy

Account Lockout duration is set to 0 and account lockout threshold is set to after 0 failed attempts, I would recommend the duration to be of a minimum of 15 minutes to stop brute force attacks, additionally, the lockout threshold recommended is to be either 3 or 5 failed attempts.

3. Audit Policy

All the audit policies are set to no auditing I recommend to go through each one and make sure to set the auditing to be compliant with the regulations starting with auditing the logon events account and machine ones as they provide auditing for failed attempts which can be crucial as this is and Indicator of Compromise

4. Security Options Policy

I recommend going through one by one of these security options focusing on User Account Controls as they are extremely important, I have seen that the Administrator account is enabled however it is best practice to disable it.



Section Four: Data Availability



Developing a Data Backup Strategy

Confidential Data	
Backup Frequency:	Real Time
Retention Period:	180 days
Confidential data are critical for business continuity so they have to be backed up daily or real-time, personally I would recommend that they are backed up real-time and have the highest retention period of all types of data and make sure that they are compliant with the regulations.	
Internal Data	
Backup Frequency:	Daily
Retention Period:	90 days
Internal data are significant as well for business continuity and should not be disclosed publicly and requires protection but is not super critical on its own, yet not as critical as confidential data so they can be backed up daily.	



Developing a Data Backup Strategy

Public Data	
Backup Frequency:	Incrementally
Retention Period:	45 days
Data that is public doesn't require the level of focus on confidentiality that the other apps need as they are already available online so they won't affect business continuity.	



Creating a Backup

Place the screenshot of the LabVM Backup screen here

Home > Virtual machines > LabVM-261419

Virtual machines

Udacity (udacitylabs.onmicrosoft.com)

+ Create Switch to classic

Filter for any field...

Name

LabVM-261419

LabVM-261419 | Backup

Virtual machine

Search

Backup now Restore VM File Recovery Stop backup Resume backup Delete backup data Restore to Secondary Region Undelete Feedback

Try our new Business Continuity Center for the at scale BCDR management of your resources protected across Azure Backup and Site Recovery.

Essentials

Recovery services vault : [vault645](#)

Subscription (move) : [Udacity CloudLabs Sub - 40](#)

Subscription ID : 52c66fdd-6f75-4276-95a9-3960c6483db3

Alerts (in last 24 hours) : [View alerts](#)

Jobs (in last 24 hours) : [View jobs](#)

Backup Pre-Check : Passed

Last backup status : Warning (Initial backup pending)

Backup policy : [LabVM-Backup \(Standard\)](#)

Oldest restore point : -

Included disk(s) : [All disks](#)

Recovery points

This list is filtered for last 30 days of recovery points. To recover from recovery point older than 30 days, as well as vault-archive, [click here](#).

Long term recovery points can be moved to vault-archive. To move all 'recommended recovery points' to vault-archive tier, [click here](#).

CRASH CONSISTENT

APPLICATION CONSISTENT

FILE-SYSTEM CONSISTENT

0

0

0

Creation time

Consistency

Recovery type

No restore points available.

< Page 1 of 1 >